Can an LLM replace the IDS analyst?



Generative AI that investigates Suricata alerts and writes detection rules — measured against ground truth

Group 13 · Bigyan Siwakoti · Binay Siwakoti · Irab Baral · Shashwat Acharya

Supervisor: Prof. Bharanidharan Shanmugam · HIT401 Capstone Project · Charles Darwin University · October 2026

No rule, no detection

A signature IDS is only as good as the rules a human analyst writes for it



Today a person does every step, for every new attack — hours to days of scarce expertise (Scarfone & Mell 2007)

Can a large language model take over the analyst's role — and what context does it need to do that job well?

Scope

- Open-source only
- Rule-based detection, no ML
- AI writes rules, never classifies traffic
- Network IDS, offline pcap replay

What research and industry practice told us

38 sources across three themes — each one shaped a design decision

Rule-based IDS

Denning 1987 · Roesch 1999 · Scarfone & Mell 2007 · Sommer & Paxson 2010

Signatures are precise and inspectable; authoring them is the bottleneck. ML detectors are hard to trust in operation.

LLMs that write rules

GRIDAI (Li et al. 2025) · GenTI (Hadi et al. 2026) · RuleAutoPilot (Rehman et al. 2026)

LLMs can draft Suricata rules — but only rules validated by actually running them can be trusted.

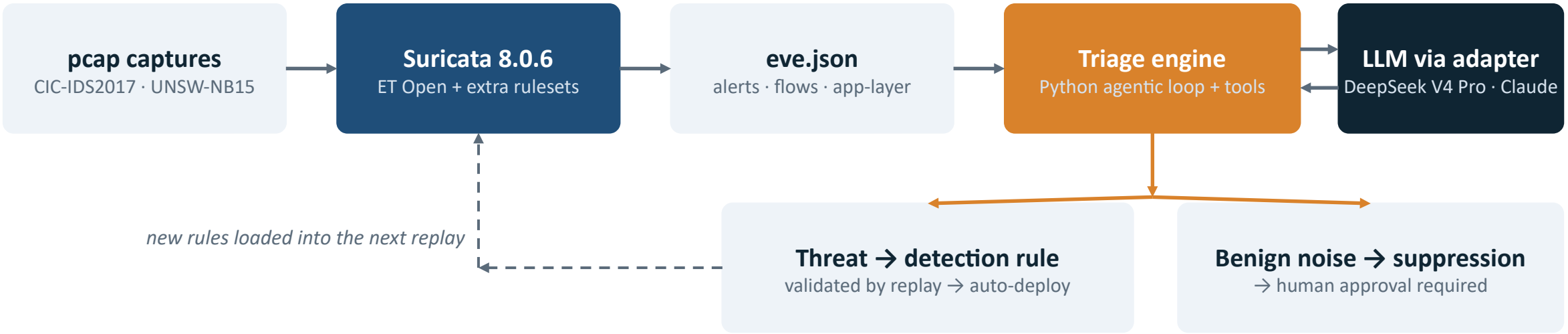
Detection engineering

Palantir ADS 2017 · SpecterOps (Atkinson 2020) · stack counting (Dragos 2023)

Document every rule, detect the technique not the tool, look at the rarest values first.

Design: keep the engine, automate the analyst

Detection stays deterministic; the model works around it through an agentic loop



Web UI (FastAPI + SSE)
pick dataset, profile & model; watch each step live; export transcript

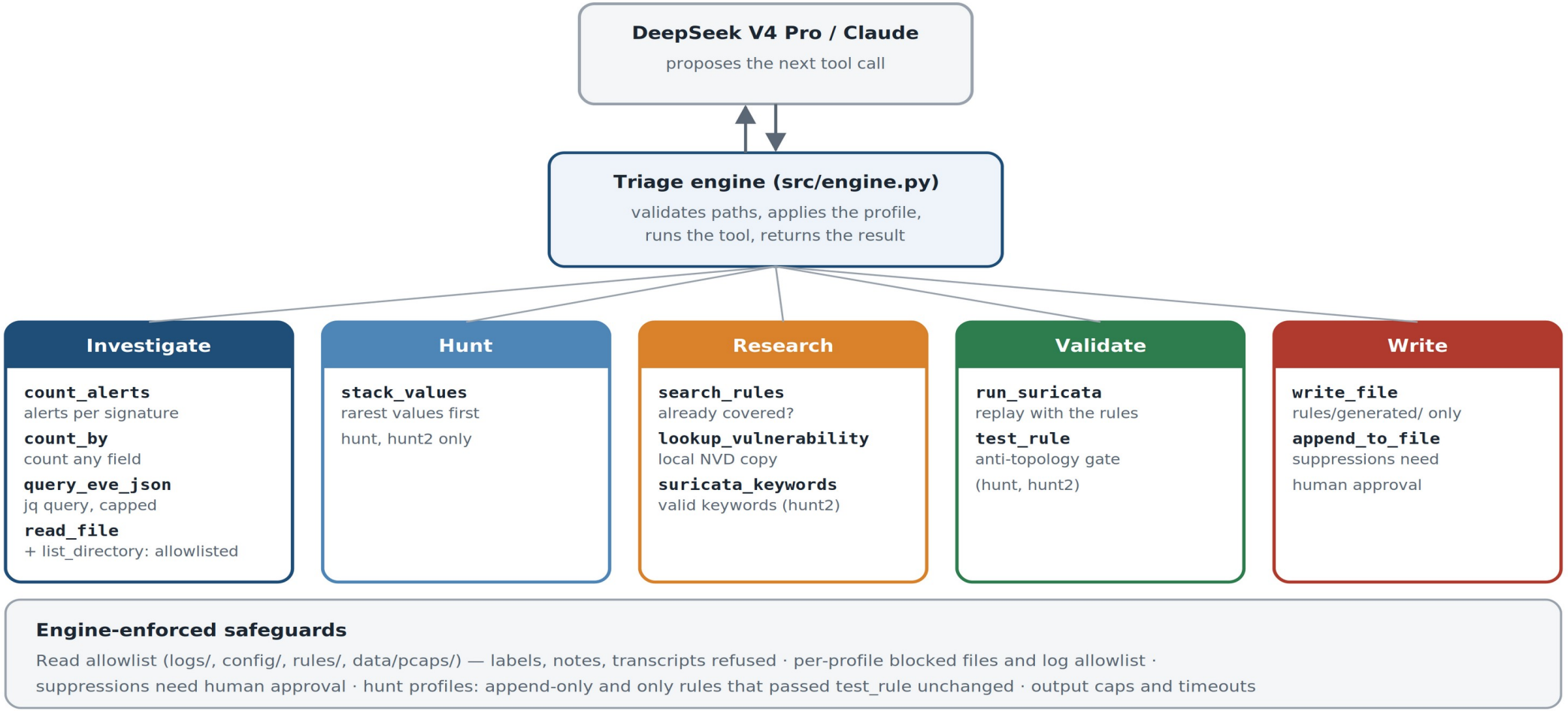
Experiment profiles
tools, prompt, config & rule file fixed per condition

Tech stack

Suricata 8.0.6 · ET Open · Python 3.12 · FastAPI · jq · tshark · DeepSeek V4 Pro · Claude · Ubuntu (WSL)

The agent’s tools: it proposes, the engine runs

13 tools in five groups; each experiment profile switches on only the ones it needs



Results: triage works on two datasets

Every number scored against the datasets' ground-truth labels — not the model's own claims

CIC-IDS2017 (development)

13 / 14
attack categories identified by the model

99.4%
of AI-rule alerts on noisy days fell on real attacks (stock rules: 6.1%)

UNSW-NB15 (never seen before)

8 / 9
attack categories identified

9.2 → 15.5%
event detection, stock ET Open → + AI rules



The safety design worked. One UNSW run proposed suppressing two rules as false positives — they were catching a real Cisco exploit. Suppressions need human approval, so the sensor was never blinded.

What the AI caught that 52,000 stock rules missed

Four examples from CIC-IDS2017 — each confirmed against the ground-truth labels



FAKEVERB DoS

Worked out that Suricata's HTTP parser hides non-standard methods, and rewrote its rule on the raw payload

0 → 463 alerts



Hulk HTTP flood

A 149,703-request cache-busting flood with no dedicated stock rule — the AI wrote and validated one

new detection



ARES botnet

Five infected hosts polling a C2 server; listed as undetected in our interim report, found later by the model

15 / 15 alerts on Bot flows



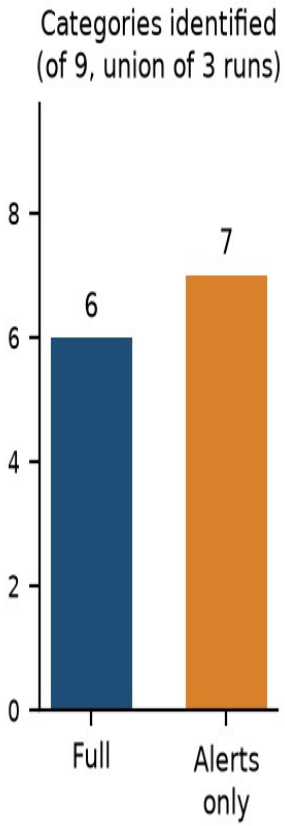
SSH brute force

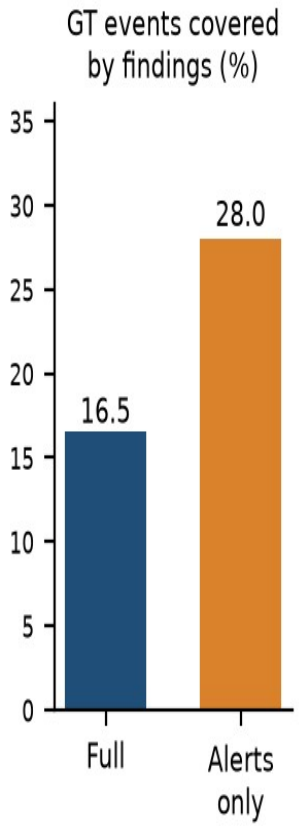
A client-fingerprint rule for the Paramiko toolkit, with no false positives

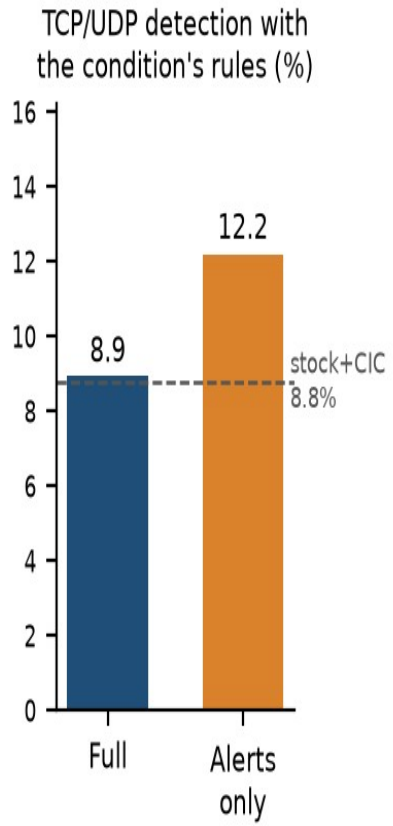
1.0% → 28.4% of flows

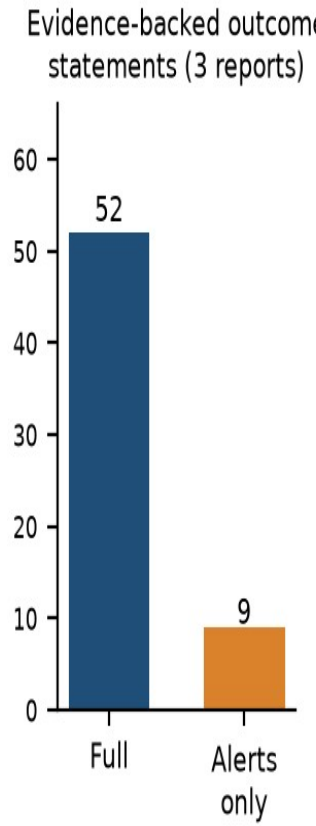
Experiment 1: what context does the model need?

Same captures (UNSW 1, 3, 10): full sensor context versus alert events only









Breadth without context

Alerts alone were enough to spot the attacks — 7 categories vs 6.

Depth with it

Only full context showed whether attacks succeeded: 52 evidence-backed outcome statements vs 9.

But its errors were confident

Why the model cannot be left unsupervised — every error below was reported as a success

Deleted two of its best rules

claiming they were stock ET rules — they were not (a hallucinated fact)

Rules that never work

3 rules Suricata rejects, 1 that can never fire — reported as validated

Misread normal traffic

routine FTP uploads from every workstation reported as data exfiltration

Opposite verdicts

same evidence, different runs: 5 said true positive, 1 said suppress

16 / 32

CIC rules that actually fired on replay — the configuration loaded only 3 of 10 rule files

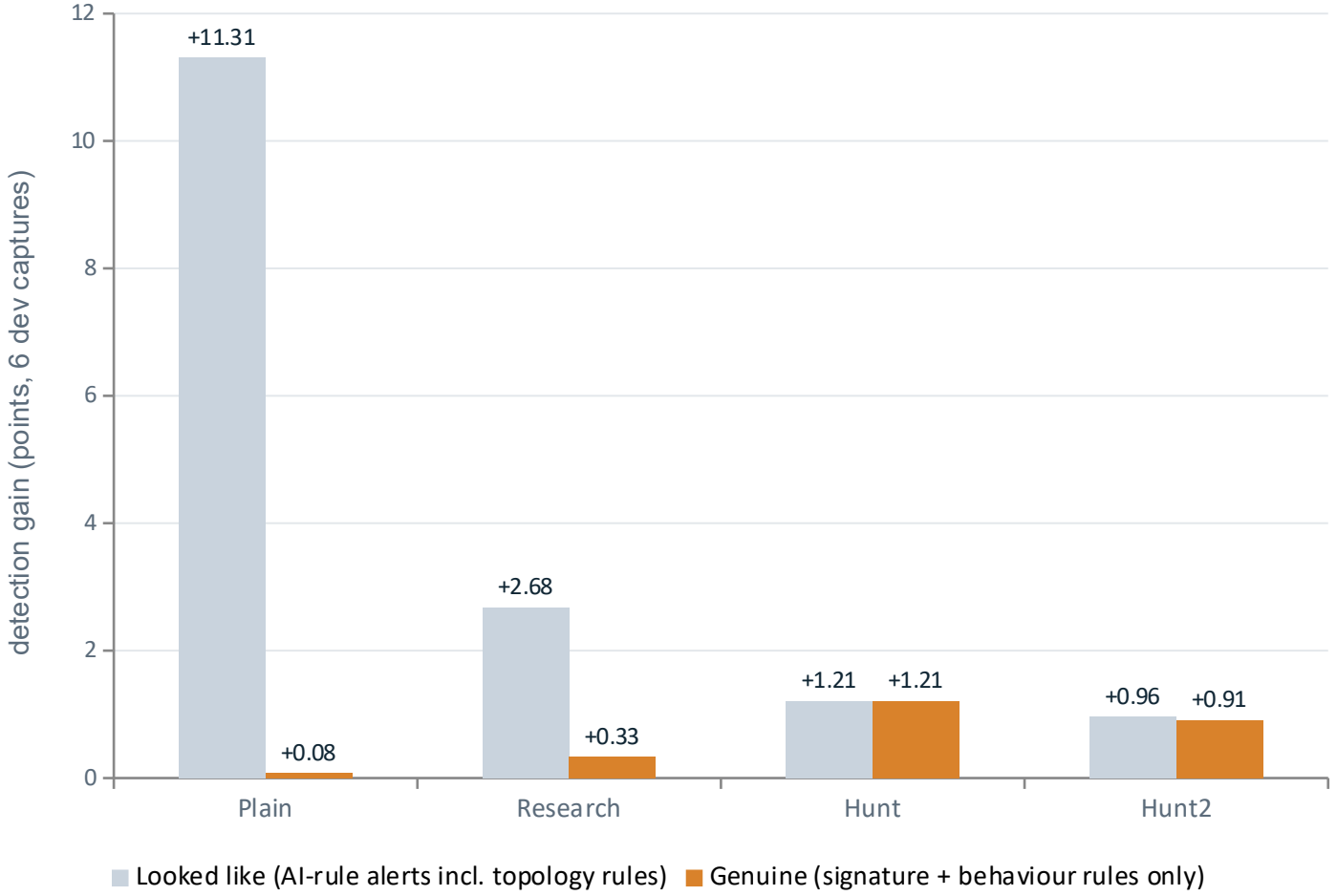
18 / 18

UNSW rules that fired, once the configuration loaded the model's file

An agent's self-validation is only as good as its environment.

Against a strong baseline: what did the AI alone catch?

UNSW baseline v2 (re-enabled rule families) detects ~25% — the bar the AI now has to clear



The topology trap

"Outside host sends mail" fires on every attacker — only because in UNSW every external host is one. Not a real detection.

Hunt = a detection engineer's workflow

Stack rare values → write a technique rule → must pass the anti-topology gate. 25 rules, 0 topology, 0 alerts on normal hosts.

We found a bug by watching the agent fail

Hunt, capture 1, first attempt: rules passed the gate — and nothing was saved

Symptom

100 turns, 8.4 M tokens. It re-tested rules that had already passed and never saved one. The UI showed tool calls but no reasoning.

Diagnosis

Checked each layer — engine, server, browser, raw API. DeepSeek V4 Pro answered in thinking mode; its reasoning came back in a field our adapter ignored.

Fix

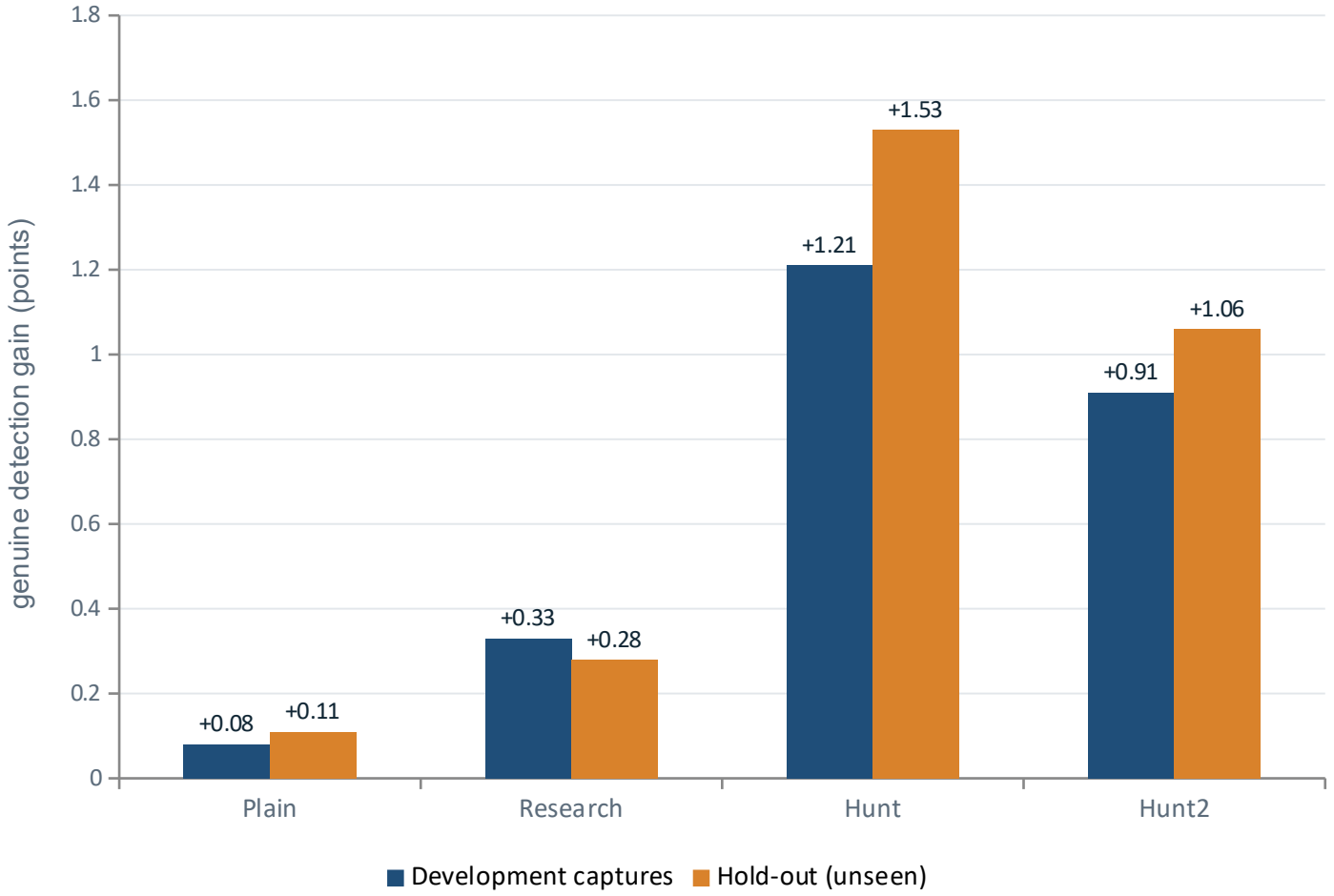
Carry the reasoning back every turn. The model kept its own plan: capture 1 finished in 90 turns and saved 9 rules.

6 → 175

attack events added by hunt rules written before vs after the fix — instance rules became technique rules

Hold-out: rules frozen, unseen traffic, scored once

UNSW 22 Jan 2015 — a day nobody looked at while building or tuning



+1.53 pts

hunt rules on unseen traffic — the gain held, and grew

0

AI-rule alerts on the benign-only hold-out captures, in every condition

29.5%

caught by the frozen human baseline alone

Answer: a split claim

What we found, what we learned, what comes next

Yes — for triage

With sensor context the model investigates end to end: 13/14 and 8/9 attack categories identified, and it can tell whether an attack succeeded.

Partly — for detection

Over a strong human baseline the engineer workflow adds +1.2 to +1.5 points with no false alarms — real, but modest.

Lessons learned

- Tools and procedure shape the agent more than the prompt
- Carry the model's reasoning between turns — dropping it made the agent loop
- Measure what the AI alone caught: our early +11 points were mostly an artefact

Next steps

- Separate the hunt workflow from the reasoning fix
- Several runs per capture — runs find different attacks
- Live network and host-based sensors